

Threat Modelling Exercise

Information Security

Threat modelling is a structured approach to identifying, communicating, and addressing potential security threats in a system. It is a proactive discipline that allows developers and security engineers to anticipate vulnerabilities before they can be exploited in production environments.

This assignment requires you to apply threat modelling techniques to realistic scenarios that mirror challenges encountered in everyday software development. You will use OWASP Threat Dragon, an open-source threat modelling tool, to design and document their threat models.

OWASP Threat Dragon is available at: <https://owasp.org/www-project-threat-dragon/>

You should familiarize themselves with the tool before attempting the scenarios below. The tool provides a diagrammatic interface for creating Data Flow Diagrams (DFDs) and automatically categorizes threats using the STRIDE methodology.

Scenario 1 (Easy): User Authentication System

Background

A small web application allows registered users to log in using a username and password. The application stores user credentials in a relational database, uses session tokens for authenticated sessions, and communicates over HTTPS. There is no multifactor authentication.

Task

1. Create a Data Flow Diagram in OWASP Threat Dragon modelling the authentication flow. Your diagram must include at minimum: the user (external entity), the web server (process), the session manager (process), and the user database (data store), with appropriate trust boundaries.
2. Identify at least four distinct threats using STRIDE, with one threat from each of any four STRIDE categories.
3. For each threat, provide:
 - Threat title and STRIDE category.
 - Description of how the threat manifests in this scenario.
 - Proposed mitigation with brief justification.

Deliverables

A completed Threat Dragon model file (.json) and a written section in your report covering the DFD description, identified threats, and mitigations.

Scenario 2 (Medium): Third-Party API Integration

Background

An e-commerce platform integrates with a third-party payment gateway to process customer transactions. The platform's backend sends payment requests to the gateway over a REST API using API keys for authentication. Transaction results are stored in an internal database and displayed to customers via the frontend. The platform also sends order confirmation emails through a third-party email service.

Task

1. Create a Data Flow Diagram in OWASP Threat Dragon for the entire transaction and notification flow. Your diagram must include trust boundaries separating internal systems from both third-party services.
2. Identify at least six distinct threats covering a minimum of five STRIDE categories.
3. For each threat, provide:
 - Threat title, STRIDE category, and severity rating (Low / Medium / High).
 - Description of how the threat manifests.
 - Proposed mitigation and justification.
4. Identify and discuss one trust boundary violation visible in the DFD and explain its security implications.

Deliverables

A completed Threat Dragon model file (.json) and a written section in your report covering the DFD description, all threats with severity ratings, the trust boundary analysis, and mitigations.

Scenario 3 (Hard): Micro services-Based Healthcare Application

Background

A healthcare organization has deployed a micro services-based patient management system. The system comprises the following services:

- Patient Portal: A web frontend through which patients access their medical records and book appointments.
- Identity Service: Handles authentication and authorization using OAuth 2.0 and issues JSON Web Tokens (JWTs).
- Medical Records Service: Stores and retrieves patient records; communicates with the identity service to verify tokens.
- Appointment Service: Manages appointment scheduling; reads patient data from the medical records service.
- Notification Service: Sends appointment reminders via SMS and email using third-party providers.
- API Gateway: Routes all inbound requests to the appropriate backend service.

All inter-service communication occurs over an internal network. The patient portal and the API gateway are exposed to the public internet.

Task

1. Create a comprehensive Data Flow Diagram in OWASP Threat Dragon encompassing all six services. Your diagram must clearly delineate trust boundaries between: (a) the public internet and the DMZ, (b) the DMZ and internal services, and (c) individual internal services.
2. Identify at least ten distinct threats covering all six STRIDE categories, with multiple threats per category where warranted.
3. For each threat, provide:
 - Threat title, STRIDE category, and severity rating (Low / Medium / High / Critical).
 - Affected component(s) and data flows.
 - Description of the attack vector and potential impact.
 - Proposed mitigation and relevant security standard or control (e.g., OWASP Top 10, NIST 800-53, and ISO 27001).
4. Identify and analyses two attack chains: sequences of two or more individual threats that, when combined, lead to a more severe compromise. For each chain, describe the steps, the compounded impact, and a strategy for breaking the chain.
5. Write a prioritized remediation plan (one page maximum) recommending the order in which mitigations should be implemented, with justification based on risk severity and implementation feasibility.

Deliverables

A completed Threat Dragon model file (.json), a written section in your report covering all threats with full details, the attack chain analyses, and the prioritized remediation plan.

Submission Requirements

You must submit the following:

1. Written Report: A single document containing:
 - A brief introduction (maximum half a page) describing your approach to threat modelling.
 - Sections for each of the three scenarios, including all required analyses.
 - A conclusion (maximum half a page) summarizing key lessons learned.
2. Threat Dragon Model Files: Three .json files exported from OWASP Threat Dragon, one per scenario, named clearly (e.g., scenario1_auth.json).